

TutorialWS - DFD Multi-diagrama com Ameaças STRIDE

Owner: Jose Rodrigues, Carlos Silva, Sara Bastos, Marta Portugal

Reviewer: Prof. Paulo Baltarejo

Contributors:

Date Generated: Tue Mar 17 2026

Executive Summary

High level system description

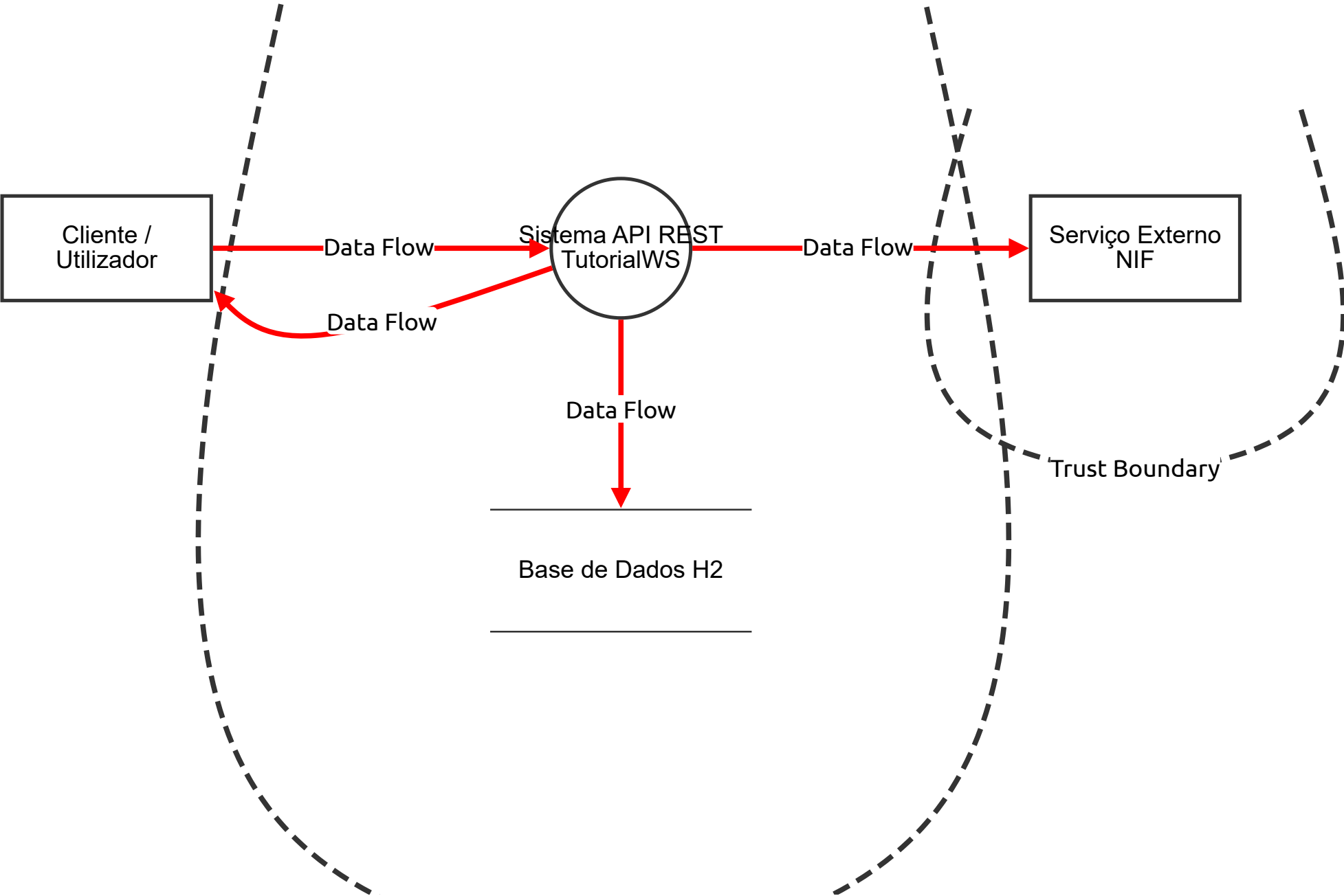
Modelo Threat Dragon com DFD de contexto, nível 1 e processos detalhados para TutorialWS. Inclui trust boundaries e ameaças

Summary

Total Threats	44
Total Mitigated	0
Total Open	44
Open / Critical Severity	0
Open / High Severity	14
Open / Medium Severity	27
Open / Low Severity	3

DFD Contexto

Visão global do sistema TutorialWS com principais entidades, stores, trust boundaries e ameaças.



DFD Contexto

Cliente / Utilizador (Actor) - *Out of Scope*

Reason for out of scope: Entidade externa ao sistema

Description: Entidade externa que consome a API REST.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Sistema API REST TutorialWS (Process)

Description: Aplicação Spring Boot que expõe endpoints para tutoriais, comentários e tags.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Ausência de autenticação nos endpoints	Spoofing	High	Open		Os endpoints REST podem ser invocados sem autenticação, permitindo ações por entidades não autorizadas.	Introduzir autenticação forte e autorização por perfil ou recurso.
2	Tratamento genérico de erros pode expor comportamento interno	Information disclosure	Medium	Open		Mensagens de erro e códigos de resposta podem facilitar a enumeração de recursos e o conhecimento do comportamento da aplicação.	Uniformizar respostas de erro e reduzir detalhe devolvido ao cliente.

Base de Dados H2 (Store)

Description: Persistência local em ficheiro H2.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Console H2 exposta no servidor	Elevation of Privilege	High	Open		A consola administrativa da base de dados encontra-se ativa, aumentando a superfície de ataque.	Desativar a consola H2 em produção ou restringir fortemente o acesso.
4	Dados persistidos sem proteção adicional	Information disclosure	Medium	Open		Os dados são armazenados em ficheiro local sem indicação de cifragem em repouso.	Aplicar controlos de acesso ao sistema de ficheiros e cifragem em repouso quando aplicável.

Serviço Externo NIF (Actor) - *Out of Scope*

Reason for out of scope: Sistema externo fora do controlo da aplicação

Description: Serviço externo de validação de NIF.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Pedidos HTTP REST (Data Flow)

Description: Fluxo de entrada de dados e pedidos aos endpoints da API.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Comunicação sem TLS	Information disclosure	High	Open		O projeto utiliza HTTP, permitindo intercepção e alteração do tráfego em trânsito.	Ativar HTTPS e redirecionar todo o tráfego HTTP para TLS.
6	Ausência de limitação de pedidos	Denial of Service	Medium	Open		Um atacante pode gerar elevado volume de pedidos e degradar o serviço.	Aplicar rate limiting e mecanismos de proteção contra abuso.

Respostas HTTP (Data Flow)

Description: Fluxo de resposta com objetos JSON e códigos de estado.							
--	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Exposição excessiva de dados em respostas	Information disclosure	Medium	Open		Respostas podem divulgar mais informação do que a estritamente necessária ao consumidor.	Aplicar princípio do mínimo privilégio e DTOs específicos para resposta.

Leitura/escrita de dados (Data Flow)

Description: Acesso lógico da aplicação à base de dados H2.							
---	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Alteração indevida de dados	Tampering	Medium	Open		A ausência de controlos de autorização pode conduzir a operações indevidas sobre dados persistidos.	Introduzir autorização por operação e validação de integridade.

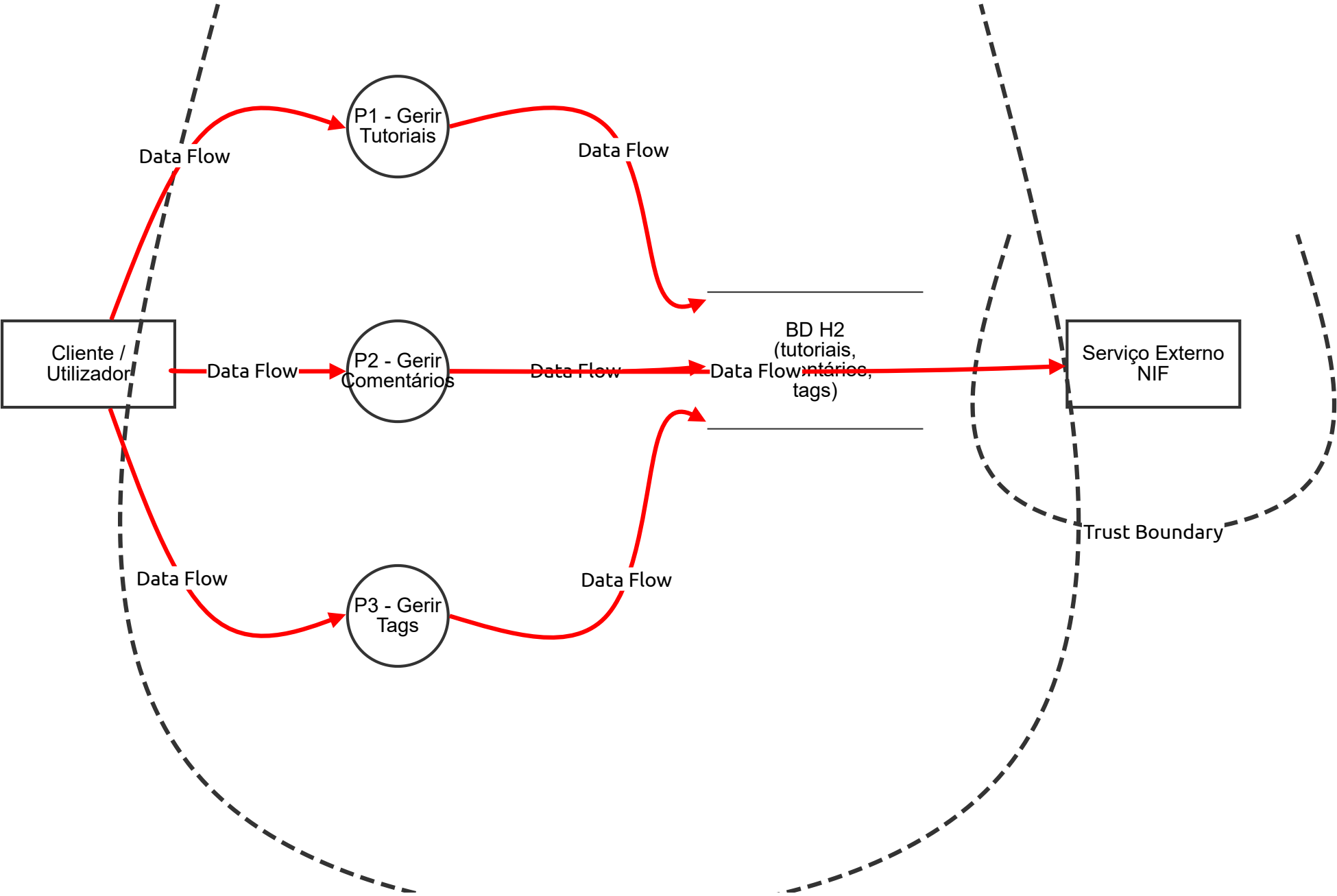
Validação de NIF (Data Flow)

Description: Pedido ao serviço externo para validação do NIF recebido.							
--	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	Dependência de serviço externo via HTTP	Tampering	High	Open		A ligação ao serviço externo é feita por HTTP, expondo o pedido e a resposta a manipulação.	Usar TLS, validar respostas e configurar timeouts e políticas de retry.
10	Indisponibilidade do serviço externo	Denial of Service	Medium	Open		A criação de comentários depende da disponibilidade do serviço de NIF.	Definir timeout, tratamento de falhas e estratégia de degradação controlada.

DFD Nível 1

Decomposição do sistema nos processos principais e respetivos fluxos de dados.



DFD Nível 1

Cliente / Utilizador (Actor) - *Out of Scope*

Reason for out of scope: Entidade externa ao sistema

Description: Consumidor externo da API.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

P1 - Gerir Tutoriais (Process)

Description: Operações CRUD e pesquisa de tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

P2 - Gerir Comentários (Process)

Description: Operações sobre comentários e validação de NIF.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Validação externa sem controlo robusto de falhas	Denial of Service	Medium	Open		A criação de comentários pode falhar em cascata devido à dependência síncrona do serviço de NIF.	Aplicar timeout, circuit breaker e tratamento explícito de indisponibilidade.

P3 - Gerir Tags (Process)

Description: Operações CRUD e associação de tags.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

BD H2 (tutoriais, comentários, tags) (Store)

Description: Armazenamento persistente da aplicação.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	Persistência local vulnerável a acesso indevido	Information disclosure	Medium	Open		O ficheiro local da base de dados pode ser acedido por utilizadores do sistema operativo sem segregação adequada.	Restringir permissões do sistema de ficheiros e separar ambientes.

Serviço Externo NIF (Actor) - *Out of Scope*

Reason for out of scope: Sistema externo fora do controlo da aplicação

Description: Serviço de terceiros para validar NIF.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Pedidos de tutoriais (Data Flow)

Description: Pedidos HTTP para /api/tutorials.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	CRUD sem autenticação	Spoofing	High	Open		As operações sobre tutoriais não exigem autenticação.	Exigir autenticação e autorização por operação.

14	Entrada não validada de forma centralizada	Tampering	Medium	Open		Dados do corpo do pedido podem ser aceites sem validação semântica suficiente.	Aplicar validação declarativa de entrada e sanitização.
----	--	-----------	--------	------	--	--	---

Pedidos de comentários (Data Flow)

Description: Pedidos HTTP para /api/comments e /api/tutorials/{id}/comments.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	Tráfego sem TLS e com dados potencialmente sensíveis	Information disclosure	High	Open		O fluxo pode transportar conteúdo e NIF sem proteção em trânsito.	Adotar HTTPS em todos os endpoints.

16	Abuso de criação de comentários	Denial of Service	Medium	Open		Pedidos sucessivos de criação podem degradar a aplicação e o serviço externo.	Aplicar rate limiting e quotas por cliente.
----	---------------------------------	-------------------	--------	------	--	---	---

Pedidos de tags (Data Flow)

Description: Pedidos HTTP para /api/tags e /api/tutorials/{id}/tags.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	CORS permissivo e sem autenticação	Spoofing	Medium	Open		A política CORS e a ausência de autenticação ampliam a exposição do processo.	Restringir origens autorizadas e autenticar clientes.

Persistência de tutoriais (Data Flow)

Description: Leitura e escrita de tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
18	Manipulação indevida de dados persistidos	Tampering	Medium	Open		Operações sem autorização podem alterar ou remover dados de tutoriais.	Introduzir controlo de acesso ao nível da operação.

Persistência de comentários (Data Flow)

Description: Leitura e escrita de comentários.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
19	Armazenamento de dados associados a NIF	Information disclosure	Medium	Open		Comentários associados a NIF podem expor dados pessoais sem necessidade clara.	Minimizar dados pessoais e rever necessidade de persistência.

Persistência de tags (Data Flow)

Description: Leitura e escrita de tags e associações.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
20	Alteração não autorizada de associações	Tampering	Medium	Open		A associação tutorial-tag pode ser alterada sem verificação de permissões.	Implementar autorização e registo de operações.

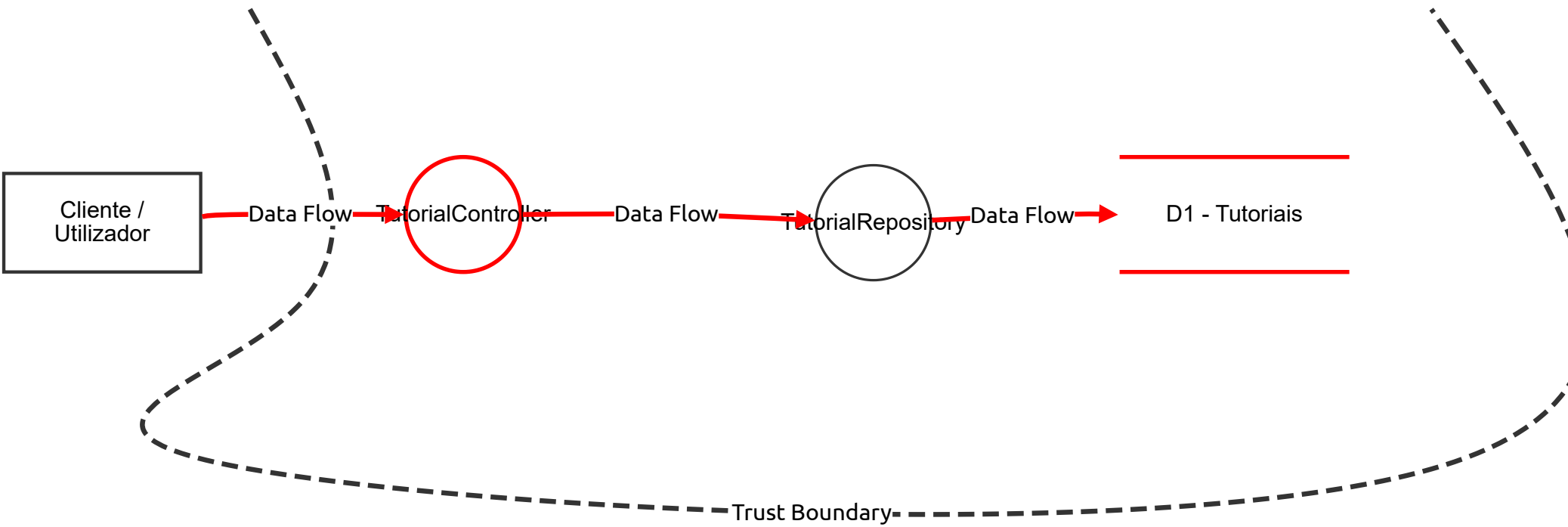
Consulta de NIF (Data Flow)

Description: Validação externa do NIF antes da criação do comentário.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
21	Canal externo sem garantia de integridade	Tampering	High	Open		A chamada ao serviço de NIF usa HTTP e não assegura integridade do conteúdo.	Usar TLS, validar payloads e tratar inconsistências.
22	Dependência operacional de terceiro	Denial of Service	Medium	Open		Falhas do serviço externo impedem a criação de comentários.	Aplicar mecanismos de tolerância a falhas.

P1 - Gerir Tutoriais

Diagrama detalhado do processo de gestão de tutoriais.



P1 - Gerir Tutoriais

Cliente / Utilizador (Actor) - *Out of Scope*

Reason for out of scope: Entidade externa ao sistema

Description: Consumidor externo.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

TutorialController (Process)

Description: Controlador REST para operações CRUD e pesquisa de tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
23	Endpoints de tutoriais sem autenticação	Spoofing	High	Open		Qualquer cliente pode criar, alterar ou remover tutoriais.	Aplicar autenticação e autorização.
24	Validação insuficiente do conteúdo recebido	Tampering	Medium	Open		Os campos do tutorial podem ser aceites sem validação formal.	Aplicar anotações de validação e regras de negócio.

TutorialRepository (Process)

Description: Repositório JPA para acesso a tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

D1 - Tutoriais (Store)

Description: Tabela/estrutura persistente de tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
25	Remoção indevida de registos	Tampering	Medium	Open		A API permite operações de remoção sem controlo de privilégios.	Restringir operações destrutivas e manter cópias de segurança.

GET/POST/PUT/DELETE /api/tutorials (Data Flow)

Description: Pedidos HTTP para criação, leitura, atualização e remoção de tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
26	Comunicação sem TLS	Information disclosure	High	Open		O tráfego de entrada pode ser observado ou alterado em trânsito.	Ativar HTTPS.

findAll/findById/save/delete (Data Flow)

Description: Invocações internas ao repositório JPA.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
27	Ausência de trilha de auditoria	Repudiation	Low	Open		Operações relevantes podem não ficar associadas a um utilizador autenticado.	Registar auditoria com identidade, data e operação.

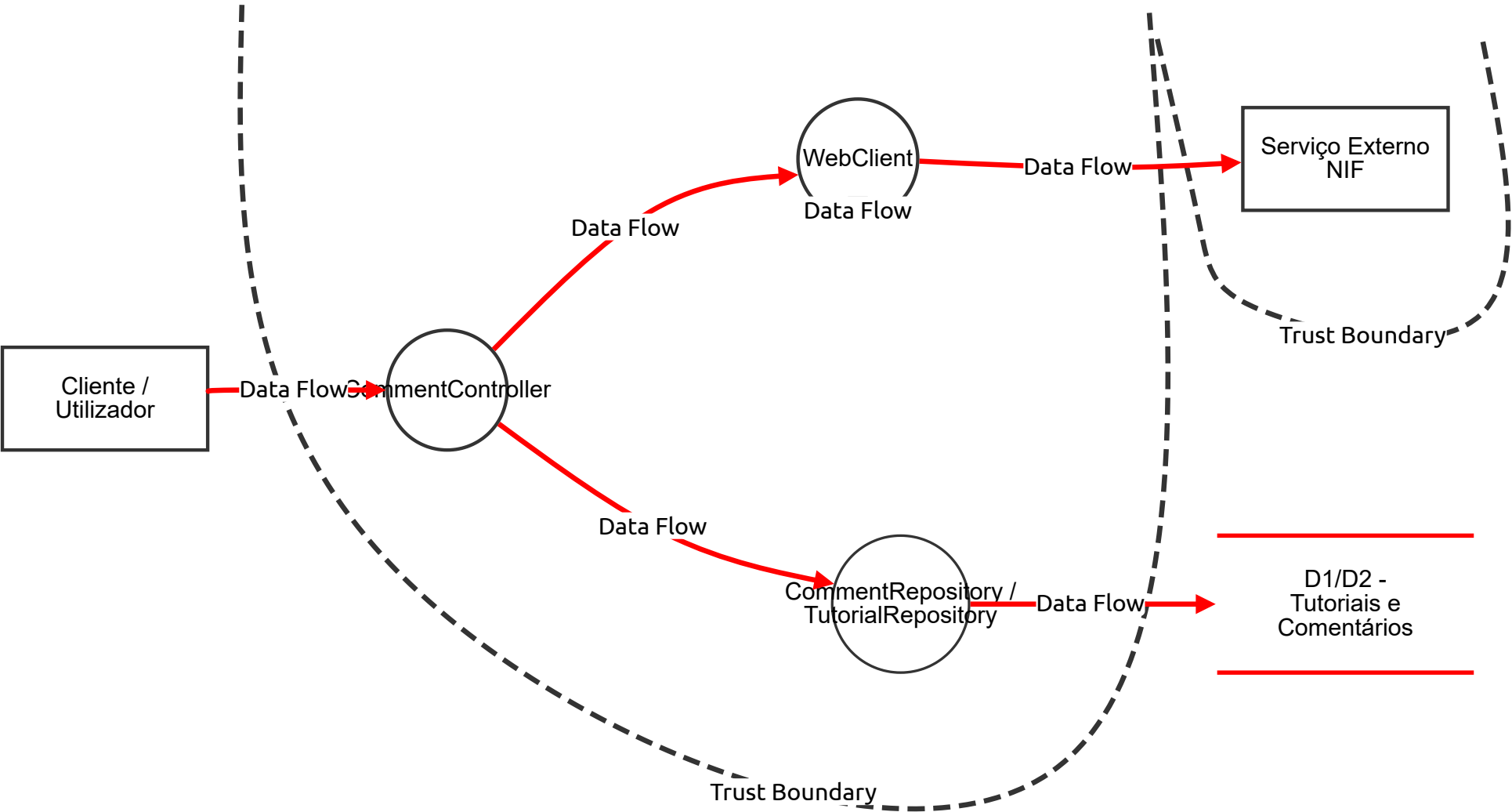
Leitura/escrita de tutoriais (Data Flow)

Description: Persistência dos dados dos tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
28	Exposição de dados por má configuração da store	Information disclosure	Medium	Open		A store pode ficar acessível através de consola ou ficheiro local.	Reforçar configuração e permissões.

P2 - Gerir Comentários

Diagrama detalhado do processo de comentários e validação externa de NIF.



P2 - Gerir Comentários

Cliente / Utilizador (Actor) - *Out of Scope*

Reason for out of scope: Entidade externa ao sistema

Description: Consumidor externo.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

CommentController (Process)

Description: Controlador REST para comentários.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
29	Criação de comentários sem autenticação	Spoofing	High	Open		A operação pode ser executada por qualquer cliente externo.	Aplicar autenticação e autorização.
30	Tratamento permissivo de falhas externas	Repudiation	Low	Open		Falhas no serviço externo podem originar respostas pouco determinísticas.	Melhorar registo e tratamento explícito de exceções.

WebClient (Process)

Description: Cliente HTTP configurado para o serviço externo de NIF.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

CommentRepository / TutorialRepository (Process)

Description: Repositórios JPA usados no processo de comentários.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

D1/D2 - Tutoriais e Comentários (Store)

Description: Dados de tutoriais e comentários.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
31	Persistência de NIF associado a comentário	Information disclosure	Medium	Open		O tratamento de um identificador pessoal aumenta o impacto de divulgação indevida.	Minimizar retenção e rever base legal/necessidade técnica.

Serviço Externo NIF (Actor) - *Out of Scope*

Reason for out of scope: Sistema externo fora do controlo da aplicação

Description: Serviço externo de validação.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

GET/POST/PUT/DELETE /api/comments (Data Flow)

Description: Pedidos HTTP relativos a comentários.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
32	Tráfego sem TLS com NIF e conteúdo	Information disclosure	High	Open		O pedido pode transportar NIF e conteúdo em texto claro.	Aplicar HTTPS em todos os endpoints.
33	Abuso de pedidos sobre comentários	Denial of Service	Medium	Open		Pedidos repetidos podem causar pressão sobre a aplicação e o serviço externo.	Aplicar rate limiting e quotas.

Pedido de validação de NIF (Data Flow)

Description: Encaminhamento interno do pedido de validação.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
34	Dependência síncrona no fluxo de negócio	Denial of Service	Medium	Open		A operação de criação fica bloqueada até resposta do serviço externo.	Aplicar timeout e circuit breaker.

HTTP GET /nifs/{id} (Data Flow)

Description: Chamada ao serviço externo configurado em HTTP.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
35	Ligação externa sem confidencialidade nem integridade	Tampering	High	Open		A resposta do serviço externo pode ser alterada em trânsito.	Usar TLS e validar a resposta recebida.
36	Falta de autenticação do serviço remoto	Spoofing	Medium	Open		Não existem evidências de autenticação mútua ou validação forte do serviço remoto.	Usar certificados válidos e validação do endpoint.

findById/exists/save/delete (Data Flow)

Description: Acesso interno a tutoriais e comentários.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
37	Operações sem segregação por utilizador	Elevation of Privilege	Medium	Open		Não existe separação de permissões entre leitura e escrita.	Introduzir perfis e verificação de autorização.

Leitura/escrita de comentários (Data Flow)

Description: Persistência de comentários e consulta de tutoriais.

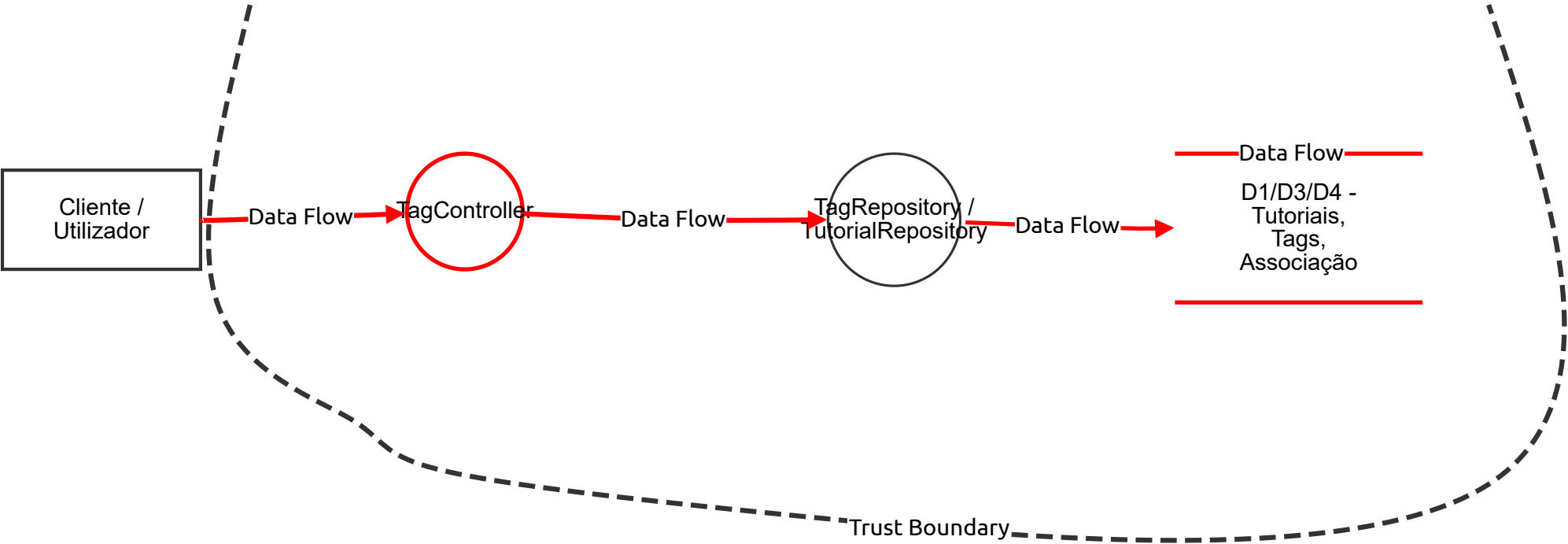
Number	Title	Type	Severity	Status	Score	Description	Mitigations
38	Divulgação de dados pessoais na store	Information disclosure	Medium	Open		Dados associados ao NIF podem ser expostos por acesso indevido à store.	Restringir acessos e rever minimização de dados.

Data Flow (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

P3 - Gerir Tags

Diagrama detalhado do processo de gestão de tags e associações.



P3 - Gerir Tags

Cliente / Utilizador (Actor) - *Out of Scope*

Reason for out of scope: Entidade externa ao sistema							
Description: Consumidor externo.							

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

TagController (Process)

Description: Controlador REST para tags e associações tutorial-tag.							
---	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
39	Gestão de tags sem autenticação	Spoofing	High	Open		A criação, atualização e remoção de tags pode ser efetuada sem autenticação.	Aplicar autenticação e autorização.

TagRepository / TutorialRepository (Process)

Description: Repositórios JPA para tags, tutoriais e associação many-to-many.							
---	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

D1/D3/D4 - Tutoriais, Tags, Associação (Store)

Description: Dados de tags e relação tutorial-tag.							
--	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
40	Alteração indevida de associações	Tampering	Medium	Open		A relação entre tutoriais e tags pode ser alterada por chamadas não autorizadas.	Aplicar autorização e registo de alterações.

GET/POST/PUT/DELETE /api/tags e /api/tutorials/{id}/tags (Data Flow)

Description: Pedidos HTTP para gestão de tags.							
--	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
41	CORS e endpoints expostos	Spoofing	Medium	Open		A exposição dos endpoints sem autenticação e com política CORS amplia a superfície de ataque.	Restringir origens autorizadas e autenticar clientes.
42	Comunicação sem TLS	Information disclosure	High	Open		Os pedidos podem ser observados ou manipulados em trânsito.	Aplicar HTTPS.

find/save/delete e associações (Data Flow)

Description: Acesso interno às operações sobre tags e tutoriais.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
43	Ausência de auditoria sobre associações	Repudiation	Low	Open		Não existe evidência de auditoria das alterações às associações tutorial-tag.	Registrar utilizador, operação e instante temporal.

Persistência de tags e relações (Data Flow)

Description: Leitura e escrita de tags e da relação many-to-many.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
44	Corrupção lógica da relação many-to-many	Tampering	Medium	Open		Associações inválidas podem comprometer a consistência lógica do sistema.	Validar integridade referencial e regras de negócio.

Data Flow (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------